PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Investigation et qualification d'incidents

03-950 ANSSI - L'investigation et la qualification d'incidents, les clés de décision — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La phase de compréhension regroupe la qualification, l'investigation et la supervision renforcée.
2. L'investigation éclaire la compromission et doit être relancée si les enjeux évoluent significativement.
3. L'arbitrage des stratégies d'investigation repose sur l'équilibre entre le coût, le retard et l'investissement pour comprendre l'attaquant.

Cadre du guide

Notion	À retenir
Objet et public	Volet stratégique destiné aux **décideurs** pour comprendre les incidents de cybersécurité d'origine **malveillante**. Complète les guides de **gestion de crise** et de **remédiation**.
La place de la compréhension	Indispensable à une **remédiation efficace** et pour **maîtriser le coût global**. Parfois nécessaire pour les obligations **CNIL**, **RGPD** ou **assurance**. Se conduit en **parallèle** de la gestion de crise et de la remédiation.

Les itérations du processus

Notion	À retenir
Qualification et investigation	L'investigation éclaire la compromission ; si les **enjeux évoluent significativement**, relancer une **qualification** pour confirmer ou redéfinir l'engagement.
Collecte et analyse	L'analyse révèle le **périmètre compromis** et les **actions de l'attaquant** ; une nouvelle collecte est justifiée par un **élargissement du périmètre**, une **méthode d'attaque particulière** ou une **activité continue**.
Investigation et supervision	L'investigation fournit des **éléments techniques** pour la **supervision dédiée**, qui observe l'**activité en cours de l'attaquant** au profit de l'investigation.

Accélérateurs et limites

Notion	À retenir
Accélérateurs à froid	Préparer : **cartographie SI**, **vulnérabilités** (audits/risques), **nature des menaces** (bulletins **CTI** du **CERT-FR**) et **périmètres d'administration** (contacts actionnables).
Limites de l'investigation	Attaquants **dynamiques/réactifs** (suppression de traces), **incertitudes** (coûts vs analyse de risque), **délais importants** (collecte sur des milliers d'équipements).

Les stratégies d'investigation

Notion	À retenir
Un jeu d'équilibriste	Arbitrage entre **coût/retard** et **investissement** pour comprendre l'attaquant. Reconstruire trop vite (pression financière, médiatique, **honte**) est un mauvais conseil.
Stratégie 1 : isolement	Coupe **tous les accès réseau** (Internet, interconnexions). Utile si **destructions imminentes** (rançongiciels), mais alerte l'attaquant et dégrade les métiers.
Stratégie 2 : environnement dégradé	Privilégie la **remédiation** après destructions importantes. L'investigation éclaire la **reprise d'activité** et les obligations légales.
Stratégie 3 : observer et contraindre	Observation temps réel (**EDR**, sondes) et **coupure systématique** des accès identifiés. Impact métier faible si détection précoce et bonne visibilité.
Stratégie 4 : observer et laisser faire	Observation discrète pour comprendre au mieux les capacités ; favorable si l'attaquant est **présent depuis longtemps**, si son retour est probable ou si la supervision était insuffisante. L'attaque continuant, fixer des **lignes rouges** métier imposant de basculer.
Stratégie 5 : investigation exploratoire	Recherche sur **large périmètre** (signalement imprécis ou chasse). Agnostique à la menace, exige des **pratiques métier homogènes**.

Sept recommandations

1. Répondre aux **objectifs stratégiques**
2. Éviter les **idées fixes** (patient zéro pas toujours atteignable)
3. **Préserver les traces** (collectes reproductibles, inventoriées, avec empreintes)
4. **Tracer** son analyse (répétable, opposable)
5. Penser aux **angles morts**
6. **Penser attaquant**
7. Ne pas rester seul : **PRIS**, prestataires Cybermalveillance, **CSIRT**

Pièges et confusions

- ⚠ Croire qu'une absence de traces prouve l'absence d'activité malveillante : elle peut traduire un manque de visibilité.
- ⚠ Choisir l'isolement sans mesurer qu'il alerte l'attaquant et dégrade les métiers, même s'il s'impose face à des destructions imminentes.
- ⚠ Penser que la recherche du patient zéro doit être une idée fixe
- ⚠ Oublier que toute incertitude non levée doit être assumée par une analyse de risque validée hiérarchiquement
- ⚠ Négliger que les collectes doivent être reproductibles, centralisées, inventoriées et assorties d'empreintes

Sigles et définitions

Qualification	Estimation de la gravité avérée et potentielle d'un incident
Investigation	Acquisition d'une connaissance technique pour comprendre les impacts et le périmètre compromis
Supervision renforcée	Supervision dédiée à l'incident avec des outils ou une vigilance accrue
Patient zéro	Premier élément compromis par l'attaquant
Ligne rouge	Seuil de risque inacceptable défini par le métier
Chasse	Recherche large et sans piste initiale d'une éventuelle présence d'attaquant
Levée de doute	Vérification d'un signalement imprécis
PRIS	Prestataire de réponse aux incidents de sécurité qualifié par l'ANSSI

Auto-test

1. Quels sont les trois éléments qui regroupent la phase de compréhension ?
2. Quel est l'objectif de l'investigation ?
3. Quelle stratégie est utile en cas de destructions imminentes par un rançongiciel ?
4. Que définit la ligne rouge ?
5. Qu'est-ce qu'un accélérateur de l'investigation ?

Réponses : **1.** La qualification, l'investigation et la supervision renforcée · **2.** Acquérir une connaissance technique pour comprendre les impacts et identifier le périmètre compromis · **3.** L'isolement · **4.** Un seuil de risque inacceptable qui impose de changer de stratégie · **5.** Des connaissances acquises à l'avance qui accélèrent et réduisent le coût de l'investigation

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.